

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporn@yandex.ru

ПРИЛОЖЕНИЕ № 1 К МЕТОДИЧЕСКИМ РЕКОМЕНДАЦИЯМ
по написанию документа «Модель угроз и нарушителей безопасности
информации»
(пример документа «Модель угроз безопасности информации» для
ИСПДн «Кадры»)

Рязань 2021

Исходные данные на информационную систему

Полное наименование информационной системы: информационная система персональных данных «Кадры» ПАО «ПРИМЕР».

Сокращённое наименование информационной системы: ИСПДн «Кадры».

Оператор информационной системы: ПАО «ПРИМЕР».

Информационная система персональных данных создана в соответствии с Приказом генерального директора ПАО «ПРИМЕР» № 1 от 11.12.2019 г.

Тип объекта информатизации: автоматизированное рабочее место, имеющее подключение к сетям общего пользования и (или) сетям международного информационного обмена.

Расположение объекта информатизации: ИСПДн «Кадры» находится по следующему адресу: 390000, г. Рязань, ул. Ленина, д.1.

Границей контролируемой зоны (далее - КЗ) являются ограждающие конструкции помещения, в котором расположено АРМ оператора.

Физический доступ в помещение, в котором расположено АРМ оператора, не ограничен входным замком. Уборка кабинета производится в присутствии лица, ответственного за организацию обработки персональных данных.

В помещениях имеется система пожарной сигнализации.

На АРМ используется сертифицированная лицензионная операционная система «Альт 8 СП Рабочая станция». В качестве прикладного ПО для работы используется программное обеспечение АРМ «Кадры», использующее базу данных Oracle, и иное программное обеспечение, не участвующее в обработке информации.

Информационные ресурсы АРМ представлены в следующем виде:

- при обработке – в виде визуализированных сведений, отображаемых на экране монитора;

- при хранении – в виде электронных документов, файлов, каталогов, базах данных (файлов баз данных), расположенных на различных носителях информации;

- при передаче – в виде сетевых пакетов в каналах связи, реализованных по модели взаимодействия открытых систем OSI/ISO, основанное на использовании защищённых каналов связи, собственного коммуникационного оборудования и собственной системы управления таким оборудованием.

Физический доступ в помещение с АРМ оператора, сетевому оборудованию ограничен.

На основании «Акт определения уровня защищенности информационный системы персональных данных «Кадры» ПАО «ПРИМЕР» от «15» декабря 2019 г для ИСПДн «Кадры» определен 3 уровень защищенности (актуальны угрозы 3 типа).

1. Цель создания информационной системы - управление процессом учета сотрудников организации и процессом бухгалтерской отчётности.

2. Задачи:

- Сбор и обработка информации о работниках;
- Формирование бухгалтерской отчётности.

Структурно-функциональная схема взаимосвязи ИСПДн «Кадры» представлена на рисунке 1.

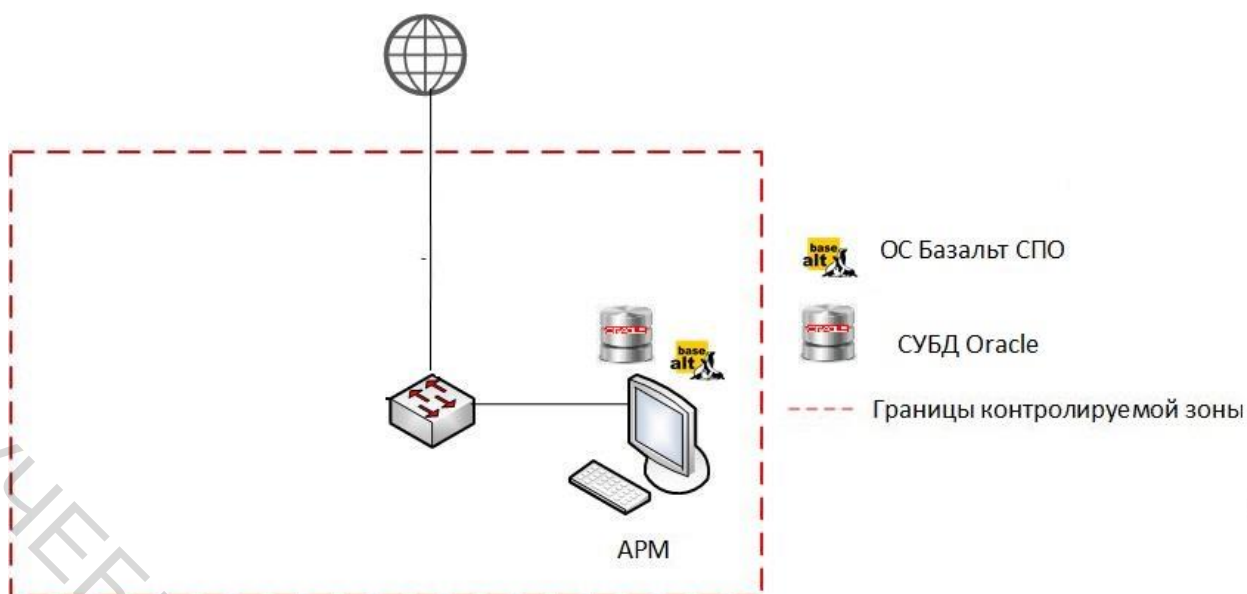


Рисунок 1. Структурно-функциональная схема ИСПДн «Кадры»

Описание технологии обработки информации.

Источник информации:

Съемные носители (USB Flash устройства);

Несъемный носитель (SATA HDD Жесткий диск – 1 шт.) АРМ.

Виды обрабатываемой информации:

- фамилия, имя, отчество работника;
- год, дата, место рождения работника;
- сведения о месте жительства работника;
- данные об образовании работника;
- сведения о семейном положении, о составе семьи работника;
- паспортные данные работника;
- сведения о воинском учете работника;
- сведения об ученой степени работника;
- контактный телефон работника;
- идентификационный номер налогоплательщика;

- сведения о номере страхового свидетельства государственного пенсионного страхования работника;
- банковские реквизиты счетов работника.

Обработка информации:

1. Осуществляется пользователями АРМ с использованием клавиатуры (устройство ввода информации). Информация обрабатывается в прикладной программе «Кадры».

2. Осуществляется пользователями АРМ над файлами, содержащими конфиденциальную информацию (копирование на другой носитель, создание нового файла, перемещение на другой носитель, удаление файла с носителя, передача информации по сети «Интернет» в другие информационные системы).

Вывод информации:

На экран монитора АРМ.

Хранение информации:

Съемные носители (USB Flash устройства);

Несъемный носитель (SATA HDD Жесткий диск – 1 шт.) АРМ.

Публичное акционерное общество «ПРИМЕР»

УТВЕРЖДАЮ

Генеральный директор
ПАО «ПРИМЕР»

_____ А.А. Иванов

М.П.

«____» _____ 2021 г.

МОДЕЛЬ УГРОЗ

безопасности информации, обрабатываемой в
информационной системе персональных данных
«Кадры»

~~(№ 10 в перечне информационных систем
ПАО «ПРИМЕР»,
размещенного на официальном сайте организации)¹~~

г. Рязань, 2021

¹ красным цветом показан пример указания сведений о наличии государственной информационной системе в Перечне таких систем организации. Для рассматриваемой информационной системы персональных данных указывать в документе «Модель угроз...» данную информацию не нужно, так как система не является государственной.

Содержание

1	Перечень принятых сокращений	8
2	Термины и их определения	9
3	Общие положения	10
3.1	Назначение и область действия документа «Модель угроз безопасности информации» ..	10
3.2	Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз	10
3.3	Сведения об обладателе информации, заказчике, операторе системы, подразделениях, ответственных за защиту информации, организации, привлекаемой для разработки модели угроз безопасности информации	12
3.4	Условия актуализации документа «Модель угроз безопасности информации»	12
4	Описание информационной системы и ее характеристика как объекта защиты	14
4.1	Общие сведения об информационной системе	14
4.2	Назначение, задачи (функции) информационной системы, состав обрабатываемой информации и ее правовой режим	15
4.3	Описание состава и архитектуры информационной системы	16
4.4	Описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа	19
5	Возможные негативные последствия от реализации (возникновения) угроз безопасности информации	23
6	Возможные объекты воздействия угроз безопасности информации и виды воздействия на них	24
7	Источники угроз безопасности информации	29
7.1	Характеристика (виды и категории) нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации	29
7.2	Определение актуальных нарушителей безопасности информации	33
8	Способы реализации угроз безопасности информации	40
9	Актуальные угрозы безопасности информации	53
9.1	Перечень возможных угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей	53
9.2	Описание возможных сценариев реализации угроз безопасности информации	54
9.3	Выводы об актуальности угроз безопасности информации	87
10.	Применение средств криптографической защиты информации	88
10.1.	Определение актуальности использования СКЗИ для обеспечения безопасности персональных данных	88
10.2.	Определение актуальности угроз, нейтрализующихся только с помощью СКЗИ	89
11.	Выводы	103

1 Перечень принятых сокращений

В настоящей модели угроз безопасности информации, обрабатываемой в информационной системе персональных данных «Кадры» приняты следующие сокращения²:

АРМ	Автоматизированное рабочее место
БИ	Безопасность информации
ЗОКИИ	Значимый объект критической информационной инфраструктуры
ИС	Информационная система
КЗ	Контролируемая зона

² В целях сокращения документа в примере указаны не все сокращения, используемые в разрабатываемом документе.

2 Термины и их определения

Автоматизированная система – система, состоящая из персонала и комплекса средств автоматизации его деятельности, реализующая информационную технологию выполнения установленных функций.

Аутентификация отправителя данных – подтверждение того, что отправитель полученных данных соответствует заявленному.

Безопасность информации – состояние защищённости информации, характеризующееся способностью пользователей, технических средств и информационных технологий обеспечить конфиденциальность, целостность и доступность информации при обработке в автоматизированных системах³.

³ В целях сокращения документа в примере указаны не все термины и их определения, используемые в разрабатываемом документе.

3 Общие положения

3.1 Назначение и область действия документа «Модель угроз безопасности информации»

В данном документе представлена модель угроз безопасности информации, обрабатываемой в информационной системе персональных данных «Кадры» ПАО «ПРИМЕР».

3.2 Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз

Модель угроз безопасности информации разрабатывается на стадии «Формирование требований к информационной системе» в соответствии с:

- Федеральным законом от 27 июля 2006 г. N 149-ФЗ «Об информации, информационных технологиях и о защите информации»;
- Федеральным законом от 27.07.2006 г. № 152-ФЗ «О персональных данных»;
- Приказом ФСТЭК России от 18.02.2013 № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»;
- Постановлением Правительства РФ от 1 ноября 2012 г. N 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;
- Методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г.;
- Методических рекомендаций по разработке нормативных правовых актов, определяющих угрозы безопасности персональных данных, актуальные при обработке персональных данных в информационных системах персональных данных, эксплуатируемых при осуществлении соответствующих видов деятельности (утверждены руководством 8 Центра ФСБ России от 31 марта 2015 г. № 149/7/2/6-432);

— Банка данных угроз безопасности информации (информационное сообщение ФСТЭК России «О банке данных угроз безопасности информации» от 6 марта 2015 г. N 240/22/879).

Настоящая Модель угроз безопасности информации сформирована в соответствии с методическими документами ФСТЭК России и ФСБ России с учетом следующих принципов:

— в случае обеспечения безопасности информации без использования СКЗИ при формировании Модели угроз безопасности информации используются методические документы ФСТЭК России;

— в случае определения Владелец или Оператором информационной системы необходимости обеспечения безопасности информации с использованием СКЗИ при формировании Модели угроз безопасности информации используются методические документы ФСТЭК России и ФСБ России.

В соответствии с ст. 13 Федерального закона от 27 июля 2006 г. N 149-ФЗ «Об информации, информационных технологиях и о защите информации» информационная система «Кадры» не является государственной и муниципальной информационной системой, следовательно, относится к иным информационным системам. В виду того, что в информационной системе обрабатываются персональные данные, данная информационная система в соответствии с положениями Федерального закона от 27 июля 2006 года № 152-ФЗ «О персональных данных» относится к информационным системам персональных данных

В соответствии со статьей 19 Федерального закона от 27 июля 2006 года № 152-ФЗ «О персональных данных», оператор информационной системы при обработке персональных данных обязуется принимать правовые, организационные и технические меры или обеспечивать их принятие для защиты персональных данных от неправомерного или случайного доступа к ним, уничтожения, изменения, блокирования, копирования, предоставления, распространения персональных данных, а также от иных неправомерных

действий в отношении персональных данных. Мероприятия по обеспечению безопасности персональных данных при их обработке в информационной системе включают в себя определение угроз безопасности персональных данных при их обработке, формирование на их основе модели угроз безопасности персональных данных при их обработке в ИС.

3.3 Сведения об обладателе информации, заказчике, операторе системы, подразделениях, ответственных за защиту информации, организации, привлекаемой для разработки модели угроз безопасности информации

Оператором информационной системы персональных данных «Кадры» (далее – ИСПДн «Кадры») является публичное автономное учреждение «ПРИМЕР» (далее - ПАО «ПРИМЕР»).

Приказом генерального директора № 10 от 23.03. 2021 г. определено должностное лицо, ответственное за обеспечение безопасности информации, обрабатываемой в ИСПДн «Кадры».

Для разработки настоящего документа по решению генерального директора привлекалась организация-лицензиат ФСТЭК России - общество с ограниченной ответственностью «Региональный центр безопасности» (далее – ООО «РЦБ»), лицензия ФСТЭК России № 0000 от 12.01.2016 г.

3.4 Условия актуализации документа «Модель угроз безопасности информации»

Модель угроз безопасности информации содержит систематизированный перечень угроз безопасности информации, реализация (возникновение) которых возможна в информационной системе, типы и категории нарушителей безопасности информации, актуальные для ИСПДн «Кадры», а также сценарии реализации угроз безопасности информации выбранными актуальными нарушителями применительно к объектам воздействия и способам воздействия на них.

Перечисленные выше составляющие документа «Модели угроз безопасности информации» могут уточняться и дополняться по мере развития способов и средств реализации угроз безопасности информации.

Модель угроз безопасности информации может быть пересмотрена в случае:

а) изменения требований нормативных правовых актов Российской Федерации, методических документов ФСТЭК России, регламентирующих вопросы оценки угроз безопасности информации;

б) изменений архитектуры и условий функционирования систем и сетей, режима обработки информации, правового режима информации, влияющих на угрозы безопасности информации;

в) выявления, в том числе по результатам контроля уровня защищенности систем и сетей и содержащейся в них информации (анализа уязвимостей, тестирований на проникновение, аудита), новых угроз безопасности информации или новых сценариев реализации существующих угроз;

г) по результатам согласования с федеральным органом исполнительной власти в области обеспечения безопасности (ФСБ России) и федеральным органом исполнительной власти, уполномоченным в области противодействия техническим разведкам и технической защиты информации (ФСТЭК России)

4 Описание информационной системы и ее характеристика как объекта защиты

4.1 Общие сведения об информационной системе

Полное наименование информационной системы: информационная система персональных данных «Кадры» ПАО «ПРИМЕР».

Сокращённое наименование информационной системы: ИСПДн «Кадры».

ИСПДн «Кадры» создана в соответствии с Приказом генерального директора ПАО «ПРИМЕР» № 1 от 11.12.2019 г.

Тип объекта информатизации: автоматизированное рабочее место, имеющее подключение к сетям общего пользования и (или) сетям международного информационного обмена.

Расположение объекта информатизации: ИСПДн «Кадры» находится по следующему адресу: 390000, г. Рязань, ул. Ленина, д.1.

Границей контролируемой зоны (далее - КЗ) являются ограждающие конструкции помещения, в котором расположено АРМ оператора. Физический доступ в помещение, в котором расположено АРМ оператора, не ограничен входным замком. Уборка кабинета производится в присутствии лица, ответственного за организацию обработки персональных данных.

В помещениях имеется система пожарной сигнализации.

На АРМ используется сертифицированная лицензионная операционная система «Альт 8 СП Рабочая станция». В качестве прикладного ПО для работы используется программное обеспечение АРМ «Кадры», использующее базу данных Oracle и иное программное обеспечение, не участвующее в обработке информации.

Информационные ресурсы АРМ представлены в следующем виде:

- при обработке – в виде визуализированных сведений, отображаемых на экране монитора;

- при хранении – в виде электронных документов, файлов, каталогов, базах данных (файлов баз данных), расположенных на различных носителях информации;

- при передаче – в виде сетевых пакетов в каналах связи, реализованных по модели взаимодействия открытых систем OSI/ISO, основанное на использовании защищённых каналов связи, собственного коммуникационного оборудования и собственной системы управления таким оборудованием.

На основании «Акт определения уровня защищенности информационный системы персональных данных «Кадры» ПАО «ПРИМЕР» от «15» декабря 2019 г для ИСПДн «Кадры» определен 3 уровень защищенности.

4.2 Назначение, задачи (функции) информационной системы, состав обрабатываемой информации и ее правовой режим

Целью создания ИСПДн «Кадры» является управление процессом учета сотрудников организации и процессом бухгалтерской отчётности.

К задачам ИСПДн «Кадры» относят:

- сбор и обработку информации о работниках;
- формирование бухгалтерской отчётности.

В ИСПДн «Кадры» обрабатываются следующие виды информации:

- фамилия, имя, отчество работника;
- год, дата, место рождения работника;
- сведения о месте жительства работника;
- данные об образовании работника;
- сведения о семейном положение, о составе семьи работника;
- паспортные данные работника;
- сведения о воинском учете работника;

- сведения об ученой степени работника;
- контактный телефон работника;
- идентификационный номер налогоплательщика;
- сведения о номере страхового свидетельства государственного пенсионного страхования работника;
- банковские реквизиты счетов работника.

В соответствии с Федеральным законом от 27 июля 2006 года № 152-ФЗ «О персональных данных» перечисленные виды информации относятся к персональным данным, подлежащим обязательной защите.

Обрабатываемые персональные данные относятся к категории иные.

Объём обрабатываемых персональных данных менее 100000 субъектов персональных данных, являющихся сотрудниками ПАО «ПРИМЕР».

Обработка информации:

1. Осуществляется пользователями АРМ (операторами АРМ) с использованием клавиатуры (устройство ввода информации). Информация обрабатывается в прикладной программе «Кадры».

2. Осуществляется пользователями АРМ (операторами АРМ) над файлами, содержащими конфиденциальную информацию (копирование на другой носитель, создание нового файла, перемещение на другой носитель, удаление файла с носителя, передача информации по сети «Интернет» в другие информационные системы).

Вывод информации:

На экран монитора АРМ.

Хранение информации:

Несъемный носитель (SATA HDD Жесткий диск – 1 шт.) АРМ.

4.3 Описание состава и архитектуры информационной системы
Структурная схема ИСПДн «Кадры» представлена на рисунке 1.

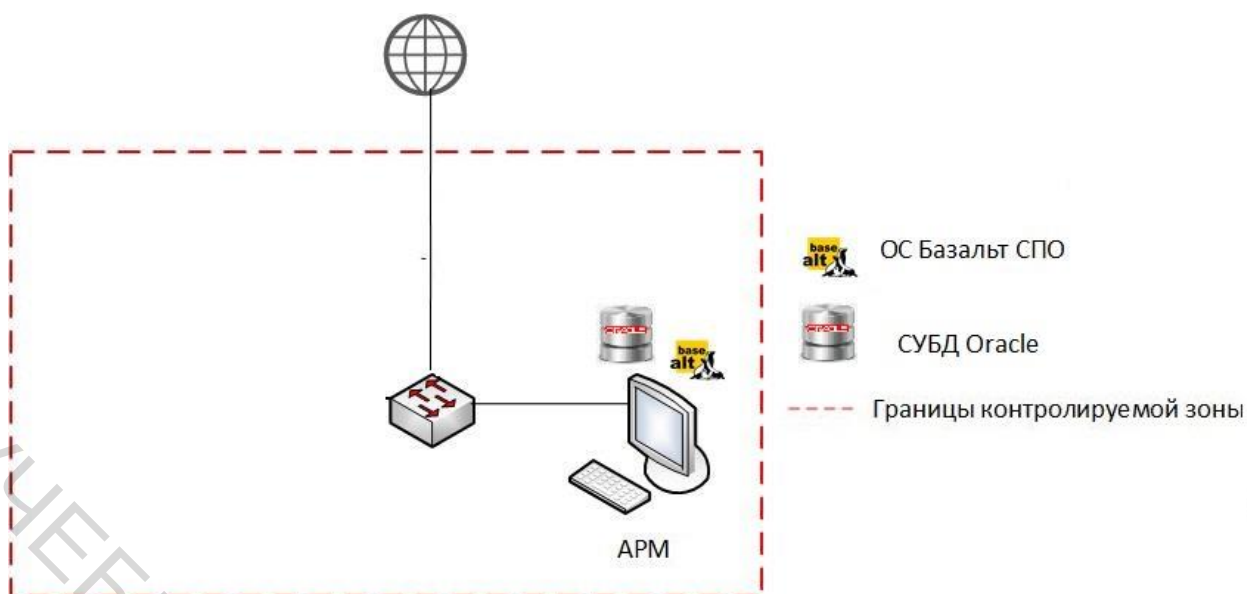


Рисунок 1. Структурная схема ИСПДн «Кадры»

В структуру ИСПДн «Кадры» (с т.з. элементной базы) входят:

а) аппаратное обеспечение/технические средства:

- 1) сетевые устройства (маршрутизаторы, коммутаторы и др.);
- 2) аппаратное обеспечение рабочих станций пользователей;

б) системное и прикладное ПО:

- 1) системное и микропрограммное обеспечение сетевых устройств;
- 2) UEFI/BIOS рабочих станций пользователей;
- 3) системное ПО АРМ пользователей;
- 4) ядро операционной системы;
- 5) связующее прикладное ПО;

6) иное программное обеспечение, которое не используется непосредственно при реализации должностных обязанностей пользователей, обрабатывающих защищаемую информацию (служебные утилиты).

Используемые технологии отражены в таблице 1.

Таблица 1 – Используемые технологии в ИСПДн

№ п/п	Характеристика	Значение характеристики
1.	Использование технологий грид-систем	Не используются
2.	Использование технологий беспроводного доступа	Не используются
3.	Использование веб-серверов	Не используются
4.	Использование технологий суперкомпьютерных систем	Не используются
5.	Использование хранилищ больших данных	Не используются
6.	Использование технологий виртуализации	Не используются
7.	Использование облачных услуг	Не используются
8.	Использование технологий удаленного доступа	Не используются
9.	Использование съемных носителей информации	Не используются
10.	Использование мобильных технических средств	Не используются
11.	Наличие подключения к сетям международного информационного обмена	Имеется

№ п/п	Характеристика	Значение характеристики
12.	Наличие взаимодействия с информационными системами сторонних организаций	Имеется
13.	Наличие внешних пользователи	Отсутствует

4.4 Описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа

Перечень информационных ресурсов ИСПДн «Кадры», к которым разграничивается доступ (объекты доступа), приведен в таблице Таблица .

Таблица 2 – Объекты доступа ИСПДн «Кадры»

№ п/п	Информационный ресурс
1.	Предметная информация, обрабатываемая и хранимая в файлах и реляционной базе данных, передаваемая по каналам связи, а также информация, выводимая на устройства отображения и печати
2.	Технологическая и служебная информация, связанная с функционированием ИСПДн «Кадры» (парольная и аутентифицирующая информация, маркеры доступа, журналы учета работы пользователей, ключевая информация, журналы регистрации событий безопасности, файлы конфигурации и прочей служебной информации)
3.	Технические средства обработки информации, системного и прикладного программного обеспечения ИСПДн «Кадры»
4.	Телекоммуникационное оборудование

5.	Программно-аппаратные комплексы и программные средства защиты информации, криптографические средства защиты информации, входящие в состав подсистемы защиты информации
6.	Каналы связи, используемые для взаимодействия ИСПДн «Кадры» с другими информационными системами

Категории лиц, имеющих санкционированный доступ к информационным ресурсам и техническим средствам ИСПДн «Кадры» (субъекты доступа), приведены в Таблице 3.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 3 – Субъекты доступа ИСПДн «Кадры»

№ п/п	Роль	Тип пользователя	Описание	Функции	Способ доступа к ИСПДн «Кадры»
1.	Оператор ИСПДн «Кадры»	Внутренний пользователь	Пользователь, имеющий санкционированный доступ к ресурсам ИСПДн «Кадры»	ввод данных в формы прикладного ПО «Кадры»	Физический доступ к ресурсам ИСПДн «Кадры»
2.	Администратор ИСПДн «Кадры»	Внутренний пользователь, эксплуатационный персонал	Лицо, обеспечивающее общее обслуживание и администрирование программного продукта, обладающее навыками по установке, настройке и администрированию программных средств и технических средств, применяемых в ИСПДн «Кадры»	установка, настройка и деинсталляция базовых программных средств и разработанного программного обеспечения в соответствии с руководством администратора по установке и настройке ИСПДн «Кадры»; диагностирование и мониторинг основных процессов ИСПДн «Кадры»; выполнение основных принципов политики информационной безопасности; ведение учетных записей пользователей ИСПДн «Кадры»	Физический доступ к ресурсам ИСПДн «Кадры»

№ п/п	Роль	Тип пользователя	Описание	Функции	Способ доступа к ИСПДн «Кадры»
				администрирование технологических процессов ИСПДн «Кадры»	
3.	Администратор информационной безопасности	Внутренний пользователь, эксплуатационный персонал	Лицо, администрирующее средства защиты информации, установленные в ИСПДн «Кадры»	обеспечение штатного функционирования средств защиты информации ИСПДн «Кадры»; контроль полномочий ролей пользователей ИСПДн «Кадры»; настройка средств защиты информации ИСПДн «Кадры»	Физический доступ к ресурсам ИСПДн «Кадры»
4.	Технический и обслуживающий персонал	Внутренний пользователь, эксплуатационный персонал	Работники сторонних организаций, осуществляющие обслуживание и ремонт технических средств ИСПДн «Кадры»	техническое обслуживание и ремонт технических средств; уборка помещений; ремонт элементов инженерно-технических сооружений и мебелировки	Ограниченный доступ в помещение с расположенным в нем АРМ оператора в сопровождении контролирующих лиц

**5 Возможные негативные последствия от реализации
(возникновения) угроз безопасности информации**

В таблице 4 представлены виды ущерба и негативные последствия от реализации угроз безопасности информации, обрабатываемой в ИСПДн «Кадры», применительно к нарушению основных процессов, выполнение которых обеспечивает ИСПДн «Кадры», и применительно к нарушению свойств безопасности информации, содержащейся в ней.

Таблица 4 - Виды ущерба и типовые негативные
последствия от реализации угроз безопасности информации

№ п/п	Виды ущерба	Возможные негативные последствия
У1	Ущерб физическому лицу	Финансовый, иной материальный ущерб физическому лицу. Нарушение конфиденциальности (утечка) персональных данных. Разглашение персональных данных граждан

6 Возможные объекты воздействия угроз безопасности информации и виды воздействия на них

В таблице 5 в соответствии с приведенными структурной схемой ИСПДн «Кадры» и информационными ресурсами, к которым осуществляется разграничение доступа, определены группы информационных ресурсов и компонентов системы, являющиеся объектами воздействия для ИСПДн «Кадры».

Таблица 5 – Объекты воздействия

№ п/п	Наименование компонентов ИСПДн	Назначение компонентов ИСПДн	Тип объекта воздействия
1.	АРМ Оператора	Обработка персональных данных сотрудников в соответствии с возложенными задачами на ИСПДн «Кадры»	АРМ
2.	Операционная система «Альт 8 СП. Рабочая станция»	Организация вычислительного процесса в системе, предоставление оператору АРМ средств, позволяющих осуществлять обработку персональных данных сотрудников в соответствии с возложенными задачами на ИСПДн «Кадры»	Системное ПО
3.	СУБД «Oracle»	Обеспечивает обработку и хранение персональных данных сотрудников, а также оптимизацию доступа к ним.	Прикладное ПО
4.	Прикладное ПО АРМ «Кадры»	Обеспечивает интерфейс взаимодействия Оператора	Прикладное ПО

№ п/п	Наименование компонентов ИСПДн	Назначение компонентов ИСПДн	Тип объекта воздействия
		АРМ с персональными данными, обработка и хранение которых осуществляется в СУБД «Oracl».	
5.	Маршрутизатор Cisco RV130	Обеспечивает взаимодействие ИСПДн «Кадры» со сторонними системами при передаче в них персональных данных.	Телекоммуни кационное оборудование
6.	Несъемный машинный носитель информации (SATA HDD Жесткий диск)	Обеспечивает хранение персональных данных, обрабатываемых в ИСПДн «Кадры».	Машинные носители информации
7.	Пользователи ИСПДн «Кадры» (Оператор АРМ, администратор системы, администратор информационной безопасности, технический и обслуживающий персонал)	В соответствии с таблицей 3	Пользователи системы

Исходя из определенных объектов воздействия, в таблице 6 приведены виды воздействия на них, а также негативные последствия, которые возникают в результате воздействий.

Таблица 6. Определение видов воздействия
и связанных с ними негативных последствий

Негативные последствия	Объекты воздействия	Виды воздействия
Финансовый, иной материальный ущерб физическому лицу (У1)	АРМ	Утечка конфиденциальной информации (информации о счетах физических лиц)
		Несанкционированная модификация защищаемой информации
		Несанкционированный доступ к защищаемой информации
	Системное и прикладное ПО	Несанкционированный доступ к системному и прикладному программному обеспечению с целью воздействия на защищаемую информацию
		Утечка конфиденциальной информации (информации о счетах физических лиц)
		Несанкционированная модификация защищаемой информации
		Перехват защищаемой информации

Негативные последствия	Объекты воздействия	Виды воздействия
	Телекоммуникационное оборудование	Несанкционированная модификация защищаемой информации
	Машинные носители информации	Утечка конфиденциальной информации (информации о счетах физических лиц)
		Несанкционированная модификация защищаемой информации
Нарушение конфиденциальности (утечка) персональных данных (У2)	АРМ	Утечка конфиденциальной информации
		Несанкционированный доступ к защищаемой информации
	Системное и прикладное ПО	Несанкционированный доступ к системному и прикладному программному обеспечению с целью воздействия на защищаемую информацию
		Утечка конфиденциальной информации
	Телекоммуникационное оборудование	Перехват защищаемой информации
	Машинные носители информации	Утечка конфиденциальной информации

Негативные последствия	Объекты воздействия	Виды воздействия
Разглашение персональных данных граждан (УЗ)	АРМ	Утечка конфиденциальной информации
	Системное и прикладное ПО	Несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации
	Телекоммуникац ионное оборудование	Перехват защищаемой информации
	Машинные носители информации	Утечка конфиденциальной информации

7 Источники угроз безопасности информации

7.1 Характеристика (виды и категории) нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации

В таблице № 7 приведены виды возможных нарушителей для ИСПДн «Кадры», а также категории нарушителей и их цели реализации угроз безопасности информации.

Исходя из целей и задач функционирования ИСПДн «Кадры», а также вида и ценности информации, обрабатываемой в системе и определенного в таблице № 4 ущерба, из перечня возможных нарушителей были исключены нарушители со средними и высокими возможностями. Пояснение по исключению данных видов нарушителей приведено в таблице № 8.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица № 7. Возможные нарушители
и их цели реализации угроз безопасности информации

№ вида	Виды нарушителя	Возможности нарушителя	Возможные цели реализации угроз безопасности информации
1	Преступные группы (криминальные структуры)	Базовые повышенные возможности (Н2)	Получение финансовой или иной материальной выгоды.
2	Отдельные физические лица (хакеры)	Базовые возможности (Н1)	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса)
3	Авторизованные пользователи систем и сетей	Базовые возможности (Н1)	Любопытство или желание самореализации (подтверждение статуса). Мсть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия
4	Системные администраторы и администраторы безопасности	Базовые повышенные возможности (Н2)	Любопытство или желание самореализации (подтверждение статуса). Мсть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия
5	Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация,	Базовые возможности (Н1)	Непреднамеренные, неосторожные или неквалифицированные действия

№ вида	Виды нарушителя	Возможности нарушителя	Возможные цели реализации угроз безопасности информации
	охрана, уборщики и т.д.)		
6	Бывшие работники (пользователи)	Базовые возможности (Н1)	Месть за ранее совершенные действия

Таблица № 8. Исключенные виды нарушителей безопасности информации, обрабатываемой в ИСПДн «Кадры»

№ п/п	Вид нарушителя	Причина исключения
1.	Специальные службы иностранных государств	ИСПДн «Кадры» не относится к государственным информационным системам, цели и задачи функционирования ИСПДн не затрагивают государственных интересов в области обеспечения обороны, безопасности, экономики и правопорядка, таким образом цели и мотивы нарушителей вида «Специальные службы иностранных государств» не могут быть достигнуты.
2.	Террористические, экстремистские группировки	Цели и задачи функционирования ИСПДн «Кадры», а также информации, обрабатываемая в системе, не позволяют нарушителям вида «Террористические, экстремистские группировки» осуществить террористические акты, нанести ущерб жизни граждан, дестабилизировать общество и деятельность органов государственной власти.
3.	Конкурирующие организации	Реализация угроз безопасности информации, обрабатываемой в ИСПДн «Кадры», не позволит нарушителю вида

№ п/п	Вид нарушителя	Причина исключения
		«Конкурирующие организации» получить конкурентное преимущество или финансовую выгоду, так как в информационной системе не обрабатывается информация, содержащая сведения о реализации бизнес процессов.
4.	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ	Нарушители данного вида не рассматриваются в качестве возможных, так как работы по установке, настройке, испытаниям, пусконаладочные и иные виды работ проводятся без привлечения сторонних организаций силами системного администратора и администратора информационной безопасности.
5.	Разработчики программных, программно-аппаратных средств	Исходя из целей и задач функционирования ИСПДн «Кадры», информация, обрабатываемая в информационной системе не несет ценности для нарушителей вида «Разработчики программных, программно-аппаратных средств».
6.	Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем	Исходя из целей и задач функционирования ИСПДн «Кадры», информация, обрабатываемая в информационной системе не несет ценности для нарушителей вида «Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем».
7.	Поставщики вычислительных услуг, услуг связи	Исходя из целей и задач функционирования ИСПДн «Кадры», информация, обрабатываемая в информационной системе не несет ценности для нарушителей вида «Поставщики вычислительных услуг, услуг связи».

7.2 Определение актуальных нарушителей безопасности информации

В соответствии с документом «Методика оценки угроз безопасности информации» нарушители признаются актуальными для систем и сетей, когда возможные цели реализации ими угроз безопасности информации могут привести к определенным для систем и сетей негативным последствиям и соответствующим рискам (видам ущерба).

Оценка целей реализации нарушителями угроз безопасности информации в зависимости от возможных негативных последствий и видов ущерба от их реализации для ИСПЛн «Кадры» приведена в таблице 9.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 9 – Оценка целей реализации нарушителями угроз безопасности информации

Виды нарушителей	Возможные цели реализации угроз безопасности информации	Соответствие целей видам риска (ущерба) и возможным негативным последствиям
	Нанесение ущерба физическому лицу	
Преступные группы (криминальные структуры)	+ (получение финансовой выгоды за счет продажи похищенных персональных данных физических лиц)	У3 (разглашение персональных данных граждан)
Отдельные физические лица (хакеры)	+ (получение финансовой или иной материальной выгоды за счет продажи похищенных персональных данных физических лиц; любопытство или желание самореализации (подтверждение статуса))	У2 (нарушение конфиденциальности (утечка) персональных данных) У3 (разглашение персональных данных граждан)

Виды нарушителей	Возможные цели реализации угроз безопасности информации	Соответствие целей видам риска (ущерба) и возможным негативным последствиям
	Нанесение ущерба физическому лицу	
Авторизованные пользователи систем и сетей	+ (любопытство или желание самореализации (подтверждение статуса); месть за ранее совершенные действия; непреднамеренные, неосторожные или неквалифицированные действия)	У1 (финансовый, иной материальный ущерб физическому лицу) У2 (нарушение конфиденциальности (утечка) персональных данных) У3 (разглашение персональных данных граждан)
Системные администраторы и администраторы безопасности	+ (любопытство или желание самореализации (подтверждение статуса); месть за ранее совершенные действия; непреднамеренные, неосторожные или неквалифицированные действия)	У1 (финансовый, иной материальный ущерб физическому лицу) У2 (нарушение конфиденциальности (утечка) персональных данных) У3

Виды нарушителей	Возможные цели реализации угроз безопасности информации	Соответствие целей видам риска (ущерба) и возможным негативным последствиям
	Нанесение ущерба физическому лицу	
		(разглашение персональных данных граждан)
Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	+ (непреднамеренные, неосторожные или неквалифицированные действия)	У2 (нарушение конфиденциальности (утечка) персональных данных)
Бывшие работники (пользователи)	+ (мсть за ранее совершенные действия)	У2 (нарушение конфиденциальности (утечка) персональных данных) У3 (разглашение персональных данных граждан)

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporzn@yandex.ru

В соответствии с документом «Методика оценки угроз безопасности информации» и оценкой уровней возможностей нарушителей, приведенной в таблице 9, определены следующие актуальные нарушители при реализации угроз безопасности информации (таблица 10).

УЧЕБНЫЙ ЦЕНТР "РЦБ" Г. РЯЗАНЬ

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

Таблица 10 – Актуальные нарушители безопасности информации

№ п/п	Виды риска (ущерба) и возможные негативные последствия	Виды актуального нарушителя	Категория нарушителя	Уровень возможностей нарушителя
1	У1 (финансовый, иной материальный ущерб физическому лицу)	Авторизованные пользователи систем и сетей	Внутренний	Н1
		Системные администраторы и администраторы безопасности	Внутренний	Н2
2	У2 (нарушение конфиденциальности; (утечка) персональных данных)	Отдельные физические лица (хакеры)	Внешний	Н1
		Авторизованные пользователи систем и сетей	Внутренний	Н1
		Системные администраторы и администраторы безопасности	Внутренний	Н2
		Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	Внутренний	Н1
		Бывшие работники (пользователи)	Внешний	Н1
3	У3	Преступные группы (криминальные структуры)	Внешний	Н2
		Отдельные физические лица (хакеры)	Внешний	Н1

№ п/п	Виды риска (ущерба) и возможные негативные последствия	Виды актуального нарушителя	Категория нарушителя	Уровень возможностей нарушителя
	(разглашение персональных данных граждан)	Авторизованные пользователи систем и сетей	Внутренний	H1
		Системные администраторы и администраторы безопасности	Внутренний	H2
		Бывшие работники (пользователи)	Внешний	H1

8 Способы реализации угроз безопасности информации

В ходе оценки способов реализации (возникновения) угроз безопасности информации определены возможные способы реализации (возникновения) угроз безопасности информации, за счет использования которых актуальными нарушителями могут быть реализованы угрозы безопасности информации в системах и сетях, – актуальные способы реализации (возникновения) угроз безопасности информации.

Для проведения оценки и определения способов реализации использованы объекты воздействия угроз безопасности информации и соответствующие им виды воздействия, определенные в п. 6 Модели, а также виды и категории актуальных нарушителей, которые могут реализовывать угрозы безопасности информации, в том числе непреднамеренные угрозы, и их возможности, определенные в соответствии с п.п. 7.2 Модели. Актуальные способы реализации угроз безопасности информации и соответствующие им виды нарушителей и их возможности приведены в таблице 11.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 11 - Актуальные способы реализации угроз безопасности информации

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
1	Преступные группы (криминальные структуры) (Н2)	Внешний	АРМ: утечка конфиденциальной информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Системное и прикладное ПО: несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей; использование уязвимостей кода программного обеспечения
			Телекоммуникационное оборудование: перехват защищаемой информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Телекоммуникационное оборудование: перехват защищаемой информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей, уязвимостей программного

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
					обеспечения сетевого оборудования
			Машинные носители информации: утечка конфиденциальной информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
2	Отдельные физические лица (хакеры) (Н1)	Внешний	АРМ: утечка конфиденциальной информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Системное и прикладное ПО: несанкционированный доступ к системному и прикладному программному	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей; использование уязвимостей кода программного обеспечения

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
			обеспечению с целью нарушения конфиденциальности информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Телекоммуникационное оборудование: перехват защищаемой информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей, уязвимостей программного обеспечения сетевого оборудования
			Машинные носители информации: утечка конфиденциальной информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
3	Авторизованные пользователи систем и сетей (Н1)	Внутренний	АРМ: утечка конфиденциальной информации, в том числе информации банковских счетов физических лиц; несанкционированная модификация защищаемой информации; несанкционированный доступ к защищаемой информации	Пользовательский интерфейс	Ошибочные действия в ходе эксплуатации информационной системы
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Системное и прикладное ПО: несанкционированный	Пользовательский интерфейс	Ошибочные действия в ходе эксплуатации информационной системы

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
			доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации утечка конфиденциальной информации, в том числе информации банковских счетов физических лиц; несанкционированная модификация защищаемой информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Машинные носители информации: утечка конфиденциальной информации; несанкционированная модификация	Пользовательский интерфейс	Ошибочные действия в ходе эксплуатации информационной системы
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
			защищаемой информации		

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
4	Системные администраторы и администраторы безопасности (Н2)	Внутренний	АРМ: утечка конфиденциальной информации, в том числе информации банковских счетов физических лиц; несанкционированная модификация защищаемой информации; несанкционированный доступ к защищаемой информации	Интерфейс для осуществления администрирования информационной системы	Ошибочные действия в ходе создания и эксплуатации информационной системы, в том числе при установке, настройке программных и программно-аппаратных средств; внедрение вредоносного программного кода; формирование скрытых каналов передачи информации; нарушение безопасности информации при администрировании информационной системы

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного кода
			Системное и прикладное ПО: несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации; утечка конфиденциальной информации, в том числе информации банковских счетов физических лиц; несанкционированная модификация защищаемой информации	Интерфейс для осуществления администрирования информационной системы	Ошибочные действия в ходе создания и эксплуатации информационной системы, в том числе при установке, настройке программных и программно-аппаратных средств; внедрение вредоносного программного кода; формирование скрытых каналов передачи информации; нарушение безопасности информации при администрировании информационной системы; использование уязвимостей кода программного обеспечения

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного кода
			Машинные носители информации: утечка конфиденциальной информации; несанкционированная модификация защищаемой информации	Интерфейс для осуществления администрирования информационной системы	Ошибочные действия в ходе создания и эксплуатации информационной системы, в том числе при установке, настройке программных и программно-аппаратных средств; внедрение вредоносного программного кода; формирование скрытых каналов передачи информации (копирование

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
					информации на съемный носитель); нарушение безопасности информации при администрировании информационной системы
5	Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.) (Н1)	Внутренний	АРМ: утечка конфиденциальной информации	Пользовательский интерфейс	Ошибочные действия в ходе обеспечения функционирования информационной системы
			Системное и прикладное ПО: несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации	Пользовательский интерфейс	Ошибочные действия в ходе обеспечения функционирования информационной системы
			Машинные носители информации: утечка	Пользовательский интерфейс	Ошибочные действия в ходе обеспечения

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
			конфиденциальной информации		функционирования информационной системы
6	Бывшие работники (пользователи) (Н1)	Внешний	АРМ: утечка конфиденциальной информации; несанкционированный доступ к защищаемой информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Системное и прикладное ПО: несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации	Внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»	Использование уязвимостей архитектуры и конфигурации сетей; использование уязвимостей кода программного обеспечения
				Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения
			Телекоммуникационное оборудование: перехват	Внешний сетевой интерфейс,	Использование уязвимостей архитектуры и

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия: вид воздействия	Доступные интерфейсы	Способы реализации
			защищаемой информации	обеспечивающих взаимодействие с сетью «Интернет»	конфигурации сетей, уязвимостей программного обеспечения сетевого оборудования
			Машинные носители информации: утечка конфиденциальной информации; несанкционированная модификация защищаемой информации	Съемные машинные носители, подключаемые к АРМ	Внедрение вредоносного программного обеспечения

9 Актуальные угрозы безопасности информации

9.1 Перечень возможных угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей

В данном разделе настоящего документа на основе анализа исходных данных определяются возможные для систем и сетей угрозы безопасности информации, к которым относятся осуществляемые нарушителем воздействия на информационные ресурсы и компоненты систем и сетей (объекты воздействия), в результате которых возможно нарушение безопасности информации и (или) нарушение или прекращение функционирования систем и сетей.

Исходными данными для определения возможных угроз являются:

- 1) негативные последствия от реализации (возникновения) угроз безопасности информации;
- 2) объекты воздействия угроз безопасности информации и виды воздействий на них;
- 3) виды и категории актуальных нарушителей, которые могут реализовывать угрозы безопасности информации, в том числе непреднамеренные угрозы, и их возможности;
- 4) актуальные способы реализации (возникновения) угроз безопасности информации.

Угроза безопасности информации возможна, если имеются нарушитель или иной источник угрозы, объект, на который осуществляются воздействия, способы реализации угрозы безопасности информации, а реализация угрозы может привести к негативным последствиям.

В соответствии с таким определением возможности реализации угрозы и на основе данных, полученных ранее в ходе анализа объектов воздействия, источников, способов реализации угроз и негативных последствий от их

реализации, определены следующие угрозы безопасности информации, обрабатываемой в рассматриваемой ИСПДн «Кадры»:

- утечки конфиденциальной информации;
- несанкционированного доступа к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации;
- перехват защищаемой информации;
- несанкционированная модификация защищаемой информации.

9.2 Описание возможных сценариев реализации угроз безопасности информации

Актуальность возможных угроз безопасности информации, перечисленных в п.п. 9.1 определяется наличием сценариев их реализации.

Сценарии реализации угроз безопасности информации определены для соответствующих способов реализации угроз безопасности информации и применительно к объектам воздействия и видам воздействия на них. Определение сценариев предусматривает установление последовательности возможных тактик и соответствующих им техник, применение которых возможно актуальным нарушителем с соответствующим уровнем возможностей, а также доступности интерфейсов для использования соответствующих способов реализации угроз безопасности информации.

Перечень основных тактик (тактических задач) и соответствующих им типовых техник, используемых для построения сценариев реализации угроз безопасности информации, приведен в приложении 11 Методического документа «Методика оценки угроз безопасности информации» (утвержден ФСТЭК России 5 февраля 2021 г.). Нумерация тактик и техник произведена с использованием названного Приложения 11. Далее в таблицах 12-... приведены сценарии реализации угроз безопасности в соответствии типом нарушителя и уровнем его возможностей и объекта воздействия.

1) Сценарии реализации угроз безопасности информации нарушителем вида «Преступные группы (криминальные структуры)» с повышенным базовым потенциалом (Н2) приведен в таблицах № 12 - 17.

Возможные угрозы безопасности информации:

- утечки конфиденциальной информации;
- несанкционированного доступа к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации;

- перехват защищаемой информации;

Объект воздействия:

- АРМ;
- системное и прикладное ПО;
- телекоммуникационное оборудование;
- машинные носители информации.

Способы реализации:

- использование уязвимостей архитектуры и конфигурации сетей
- внедрение вредоносного программного обеспечения посредством съемных машинных носителей информации, подключаемых к АРМ.
- использование уязвимостей архитектуры и конфигурации сетей, уязвимостей программного обеспечения сетевого оборудования.

В таблице № 12 приведены сценарии реализации угрозы безопасности информации «Утечки конфиденциальной информации» для:

- объекта воздействия – **АРМ;**
- доступного интерфейса – **внешний сетевой интерфейс;**
- способа реализации - **использование уязвимостей архитектуры и конфигурации сетей.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 12 – Сценарии реализации УБИ «Утечка конфиденциальной информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программами	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Сокращение действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Использование уязвимостей архитектуры и конфигурации сетей	T1.2 Сбор информации о подключённых к публичным источникам устройствах	T2.3. Эксплуатация уязвимостей сетевого оборудования		T4.1. Несанкционированное создание учетных записей или кража существующих учетных данных		T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	T7.2. Очистка/затирание истории команд и журналов регистрации		T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	
	T1.3 Пассивный сбор информации о сетевых устройствах	T2.4. Использование ошибок конфигурации и сетевого оборудования и средств защиты		T4.2. Использование штатных средств удаленного доступа и управления операционной системы		T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи	T7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей		T9.2. Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Сокращение действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
	T1.4 Направленное сканирование сети	T2.5. Эксплуатация уязвимостей компонентов систем и сетей				T6.3 Эксплуатация уязвимостей ПО к повышению привилегий	T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
	T1.5 Сбор информации о пользователях, устройствах	T2.6. Использование недокументированных возможностей ПО компонентов сети				T6.7. Использование уязвимостей конфигурации и системы, служб и приложений			T9.4. Вывод информации на нестандартные порты на внешних серверах	
									T9.6. Отправка данных по собственным протоколам	

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporn@yandex.ru

В таблице № 13 приведены сценарии реализации угрозы безопасности информации «Утечки конфиденциальной информации» для:

- объекта воздействия – АРМ;
- доступного интерфейса – съемные машинные носители, подключаемые к АРМ;
- способа реализации - внедрение вредоносного программного обеспечения посредством съемных машинных носителей информации, подключаемых к АРМ.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 13 – Сценарии реализации УБИ «Утечка конфиденциальной информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Внедрение вредоносного программного обеспечения посредством съемных машинных носителей информации, подключаемых к АРМ	T1.1 Сбор информации из публичных источников	T2.7. Использование в системе внешних носителей информации	T3.1. Автоматический запуск скриптов и исполняемых файлов		T5.1. Удаленное управление через стандартные протоколы	T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	T7.2. Очистка/затирание истории команд и журналов регистрации		T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	+
	T1.11. Сбор информации о пользователях, путем применения социальной инженерии	T2.8. Использование методов социальной инженерии	T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим		T5.2. Использование штатных средств удаленного доступа	T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи	T7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей		T9.2. Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
			запуском на выполнение							
					T5.3. Коммуникация с внешними серверами управления через хорошо известные порты на этих серверах		T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
									T9.4. Вывод информации на нестандартные порты на внешних серверах	
									T9.6. Отправка	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
									данных по собственным протоколам	

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporzn@yandex.ru

В таблице № 14 приведены сценарии реализации угрозы безопасности информации «Несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации» для:

- объекта воздействия – **системное и прикладное ПО;**
- доступного интерфейса – **внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»;**
- способа реализации - **использование уязвимостей архитектуры и конфигурации сетей, использование уязвимостей кода программного обеспечения.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

Таблица 14 – Сценарии реализации УБИ «Несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Использование уязвимостей архитектуры и конфигурации сетей	T1.2 Сбор информации о подключённых к публичным источникам устройствах	T2.3. Эксплуатация уязвимостей сетевого оборудования		T4.1. Несанкционированное создание учетных записей или кража существующих учетных данных		T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	T7.2. Очистка/затирание истории команд и журналов регистрации		T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	
	T1.3 Пассивный сбор информации о сетевых устройствах	T2.4. Использование ошибок конфигурации и сетевого оборудования и средств защиты		T4.2. Использование штатных средств удаленного доступа и управления операционной системы		T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной	T7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей		T9.2. Доступ к системе для сбора информации и вывод информации через использованные штатные средств	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
						учетной записи			удаленного доступа	
	T1.4 Направленное сканирование сети	T2.5. Эксплуатация уязвимостей компонентов систем и сетей				T6.3 Эксплуатация уязвимостей ПО к повышению привилегий	T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
	T1.5 Сбор информации о пользователях, устройствах	T2.6. Использование недокументированных возможностей ПО компонентов сети				T6.4. Эксплуатация уязвимостей механизма имперсонации			T9.4. Вывод информации на нестандартные порты на внешних серверах	
						T6.7. Использование уязвимостей			T9.6. Отправка данных по	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
						конфигурации и системы, служб и приложений			собственным протоколам	
						T6.8. Эксплуатация уязвимостей, связанных с отдельным, и вероятно менее строгим контролем доступа к некоторым ресурсам				

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporzn@yandex.ru

В таблице № 15 приведены сценарии реализации угрозы безопасности информации «Несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации» для:

- объекта воздействия – **системное и прикладное ПО;**
- доступного интерфейса – **съемные машинные носители, подключаемые к АРМ;**
- способа реализации - **внедрение вредоносного программного обеспечения.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

Таблица 15 – Сценарии реализации УБИ «Несанкционированный доступ к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Внедрение вредоносного программного обеспечения посредством съемных машинных носителей информации, подключаемых к АРМ	T1.1 Сбор информации из публичных источников	T2.7. Использование в системе внешних носителей информации	T3.1. Автоматический запуск скриптов и исполняемых файлов		T5.1. Удаленное управление через стандартные протоколы	T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	T7.2. Очистка/затирание истории команд и журналов регистрации		T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	+
	T1.11. Сбор информации о пользователях, путем применения	T2.8. Использование методов социальной инженерии	T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта		T5.2. Использование штатных средств удаленного доступа	T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной	T7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование		T9.2. Доступ к системе для сбора информации и вывод информации через использование штатных	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносным программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
	социальной инженерии		или ресурса с последующим запуском на выполнение			учетной записи	ние съемных носителей		средств удаленного доступа	
					T5.3. Коммуникация с внешними серверами управления через хорошо известные порты на этих серверах		T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
									T9.4. Вывод информации на нестандартны	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
									е порты на внешних серверах	
									T9.6. Отправка данных по собственным протоколам	

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporn@yandex.ru

В таблице № 16 приведены сценарии реализации угрозы безопасности информации «Перехват защищаемой информации» для:

- объекта воздействия – **телекоммуникационное оборудование;**
- доступного интерфейса – **внешний сетевой интерфейс, обеспечивающих взаимодействие с сетью «Интернет»;**
- способа реализации - **использование уязвимостей архитектуры и конфигурации сетей, уязвимостей программного обеспечения сетевого оборудования.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

Таблица 16 – Сценарии реализации УБИ «Перехват защищаемой информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	Т1. Сбор информации о системах и сетях	Т2. Получение первоначального доступа к компонентам систем и сетей	Т3. Внедрение и исполнение вредоносного ПО	Т4. Закрепление в системе или сети	Т5. Управление вредоносными программами	Т6. Повышение привилегий по доступу к компонентам систем и сетей	Т7. Соккрытие действий	Т8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	Т9. Сбор и вывод из системы или сети информации и угроз	Т10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Использование уязвимостей архитектуры и конфигурации сетей	Т1.2 Сбор информации о подключённых к публичным источникам устройствах	Т2.3. Эксплуатация уязвимостей сетевого оборудования				Т6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	Т7.2. Очистка/затирание истории команд и журналов регистрации		Т9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	
	Т1.3 Пассивный сбор информации о сетевых устройствах	Т2.4. Использование ошибок конфигурации и сетевого оборудования и средств защиты				Т6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи	Т7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей		Т9.2. Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
	T1.4 Направленное сканирование сети	T2.5. Эксплуатация уязвимостей компонентов систем и сетей				T6.3 Эксплуатация уязвимостей ПО к повышению привилегий	T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
	T1.5 Сбор информации о пользователях, устройствах	T2.6. Использование недокументированных возможностей ПО компонентов сети				T6.4. Эксплуатация уязвимостей механизма имперсонации			T9.4. Вывод информации на нестандартные порты на внешних серверах	
		T2.13. Реализация атаки типа «человек посередине» для				T6.7. Использование уязвимостей конфигурации и системы,			T9.6. Отправка данных по собственным протоколам	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
		осуществления доступа				служб и приложений				
						T6.8. Эксплуатация уязвимостей, связанных с отдельным, и вероятно менее строгим контролем доступа к некоторым ресурсам				

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporn@yandex.ru

В таблице № 17 приведены сценарии реализации угрозы безопасности информации «Утечка конфиденциальной информации» для:

- объекта воздействия – **машинные носители информации;**
- доступного интерфейса – **съёмные машинные носители, подключаемые к АРМ;**
- способа реализации - **внедрение вредоносного программного обеспечения.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 17 – Сценарии реализации УБИ «Утечка конфиденциальной информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Внедрение вредоносного программного обеспечения посредством съемных машинных носителей информации, подключаемых к АРМ	T1.1 Сбор информации из публичных источников	T2.7. Использование в системе внешних носителей информации	T3.1. Автоматический запуск скриптов и исполняемых файлов		T5.1. Удаленное управление через стандартные протоколы	T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи	T7.2. Очистка/затирание истории команд и журналов регистрации		T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	
	T1.11. Сбор информации о пользователях, путем применения социальной инженерии	T2.8. Использование методов социальной инженерии	T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим		T5.2. Использование штатных средств удаленного доступа	T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи	T7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей		T9.2. Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
			запуском на выполнение							
					T5.3. Коммуникация с внешними серверами управления через хорошо известные порты на этих серверах		T7.4. Отключение средств защиты от угроз информационной безопасности		T9.3. Вывод информации на хорошо известные порты на внешних серверах	
									T9.4. Вывод информации на нестандартные порты на внешних серверах	
									T9.6. Отправка	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
									данных по собственным протоколам	

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

2) Сценарии реализации угроз безопасности информации нарушителем вида «Авторизованные пользователи систем и сетей» с базовым потенциалом (Н1) приведен в таблицах № 18 - 19.

Возможные угрозы безопасности информации:

- утечки конфиденциальной информации;
- несанкционированного доступа к системному и прикладному программному обеспечению с целью нарушения конфиденциальности информации;
- несанкционированная модификация защищаемой информации;

Объект воздействия:

- АРМ;
- системное и прикладное ПО;
- машинные носители информации.

Способы реализации:

- ошибочные действия в ходе эксплуатации информационной системы;
- внедрение вредоносного программного обеспечения.

В таблице № 18 приведены сценарии реализации угрозы безопасности информации «Утечка конфиденциальной информации» для:

- объекта воздействия – **АРМ;**
- доступного интерфейса – **пользовательский интерфейс;**
- способа реализации – **ошибочные действия в ходе эксплуатации информационной системы.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 18 – Сценарии реализации УБИ «Утечка конфиденциальной информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Ошибочные действия в ходе эксплуатации информационной системы; внедрение вредоносного программного обеспечения			T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим запуском на выполнение						T9.3. Вывод информации на хорошо известные порты на внешних серверах	
									T9.4. Вывод информации на нестандартные порты на внешних серверах	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
									T9.6. Отправка данных по собственным протоколам	

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

В таблице № 19 приведены сценарии реализации угрозы безопасности информации «Несанкционированная модификация защищаемой информации» для:

- объекта воздействия – **АРМ;**
- доступного интерфейса – **пользовательский интерфейс;**
- способа реализации – **внедрение вредоносного программного обеспечения.**

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ**

«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporn@yandex.ru

Таблица 19 – Сценарии реализации УБИ «Несанкционированная модификация защищаемой информации»

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
Ошибочные действия в ходе эксплуатации информационной системы; внедрение вредоносного программного обеспечения			T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим запуском на выполнение						T9.3. Вывод информации на хорошо известные порты на внешних серверах	T10.7. Подмена информации
									T9.4. Вывод информации на нестандартные порты на внешних серверах	

Способ реализации угрозы	Наименование тактики реализации угрозы безопасности информации									
	T1. Сбор информации о системах и сетях	T2. Получение первоначального доступа к компонентам систем и сетей	T3. Внедрение и исполнение вредоносного ПО	T4. Закрепление в системе или сети	T5. Управление вредоносными программным обеспечением	T6. Повышение привилегий по доступу к компонентам систем и сетей	T7. Соккрытие действий	T8. Получение доступа (распространение доступа) к другим компонентам систем и сетей	T9. Сбор и вывод из системы или сети информации и угроз	T10. Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям
									T9.6. Отправка данных по собственным протоколам	

ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ

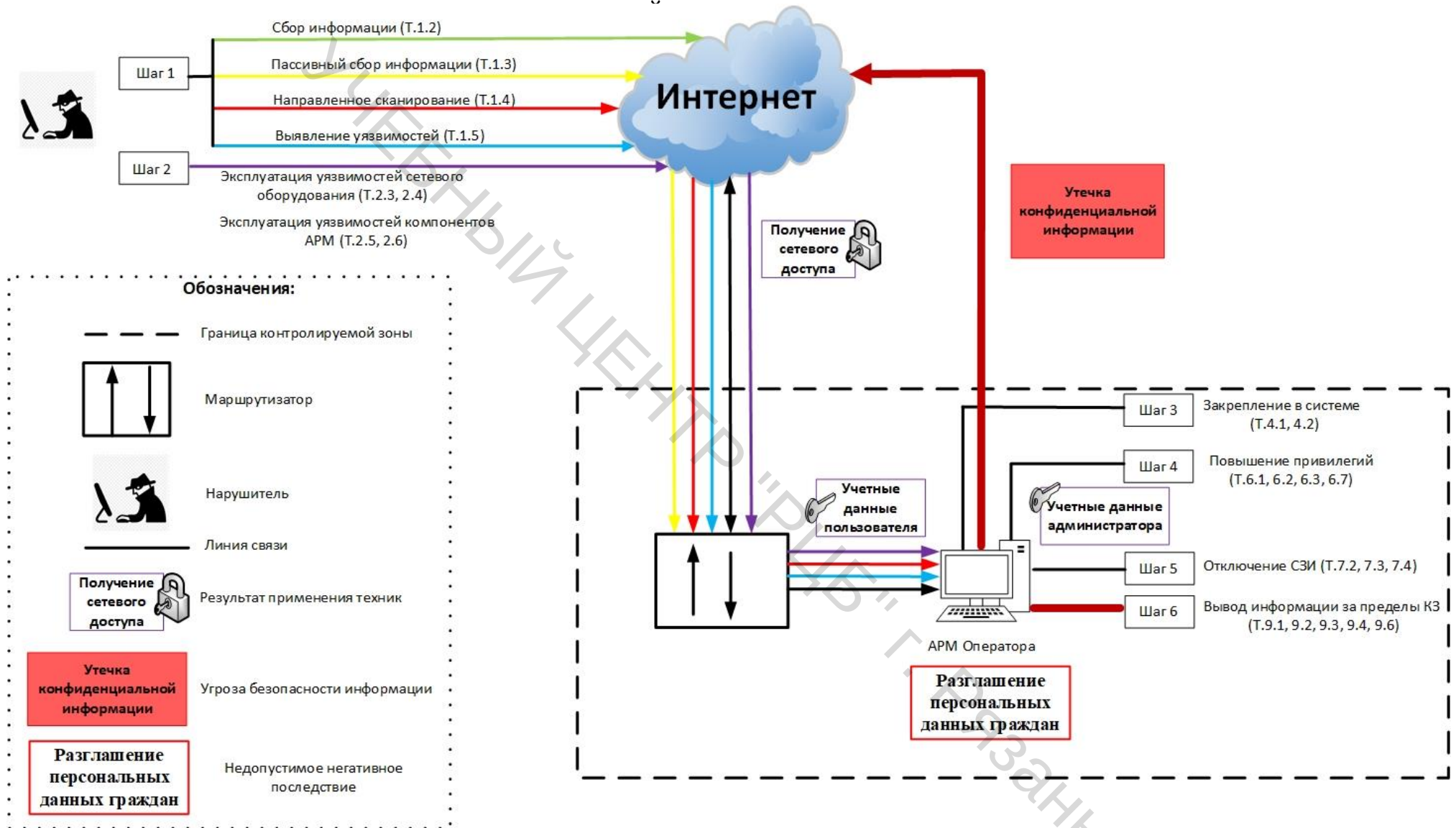


Рисунок № 1. Сценарий реализации угрозы безопасности информации «Утечка конфиденциальной информации» (таблица № 12)

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporzn@yandex.ru

В целях сокращения объема методического пособия в данном примере рассмотрены не все виды нарушителей и объекты воздействия. Для не рассмотренных видов нарушителей, объектов воздействия и способов воздействия на них сценарии реализации угроз строятся точно по таким же принципам.

УЧЕБНЫЙ ЦЕНТР "РЦБ" г. Рязань

9.3 Выводы об актуальности угроз безопасности информации

Актуальность возможных угроз безопасности информации, выделенных в п.п 9.1 определяется наличием сценариев их реализации. При наличии хотя бы одного сценария угрозы безопасности информации такая угроза признается актуальной для ИСПДн «Кадры» и включается в модель угроз безопасности для обоснования выбора организационных и технических мер по защите информации (обеспечению безопасности), а также выбора средств защиты информации.

10. Применение средств криптографической защиты информации

10.1. Определение актуальности использования СКЗИ для обеспечения безопасности персональных данных

В связи с тем, что передача персональных данных производится по каналам связи, не защищённым от перехвата нарушителем передаваемой по ним информации, а также от несанкционированных воздействий на эту информацию (по информационно-телекоммуникационным сетям общего пользования), в соответствии с пунктом 2 Методических рекомендаций ФСБ России № 149/7/2/6-432 от 31.03.2015 в ИСПДн необходимо использование СКЗИ.

При этом необходимо учитывать следующее:

- криптографическая защита персональных данных может быть обеспечена при условии отсутствия возможности несанкционированного доступа нарушителя к ключевой информации СКЗИ;
- СКЗИ штатно функционируют совместно с техническими и программными средствами, которые способны повлиять на выполнение предъявляемых к СКЗИ требований и которые образуют среду функционирования СКЗИ;
- СКЗИ не предназначены для защиты информации от действий, выполняемых в рамках предоставленных субъекту действий полномочий (например, СКЗИ не предназначены для защиты персональных данных от раскрытия лицами, которым предоставлено право на доступ к этой информации);
- СКЗИ обеспечивают защиту информации при условии соблюдения требований эксплуатационно-технической документации на СКЗИ и требований действующих нормативных правовых документов в области реализации и эксплуатации СКЗИ;

– для обеспечения безопасности персональных данных при их обработке в информационной системе должны использоваться СКЗИ, прошедшие в установленном порядке процедуру оценки соответствия.

– в случае отсутствия прошедших в установленном порядке процедуру оценки соответствия СКЗИ, функционально пригодных для обеспечения безопасности персональных данных при их обработке в конкретной информационной системе, на этапе аванпроекта или эскизного (эскизно-технического) проекта разработчиком информационной системы с участием оператора (уполномоченного лица) и предполагаемого разработчика СКЗИ готовится обоснование целесообразности разработки нового типа СКЗИ и определяются требования к его функциональным свойствам. Решение о разработке нового типа СКЗИ может быть принято оператором в инициативном порядке в независимости от наличия СКЗИ, функционально пригодных для обеспечения безопасности персональных данных при их обработке в конкретной ИСПДн. Разработка нового типа СКЗИ осуществляется в соответствии с Положением о разработке, производстве, реализации и эксплуатации шифровальных (криптографических) средств защиты информации, утвержденным приказом ФСБ России от 9 февраля 2005 г. № 66;

– СКЗИ являются как средством защиты персональных данных, так и объектом защиты.

10.2. Определение актуальности угроз, нейтрализуемых только с помощью СКЗИ

В соответствии с нормативными документами ФСБ России к объектам защиты, в данном случае, кроме персональных данных, относятся:

1. СКЗИ;
2. среда функционирования СКЗИ (далее - СФ);

3. информация, относящаяся к криптографической защите персональных данных, включая ключевую, парольную и аутентифицирующую информацию СКЗИ;

4. документы, дела, журналы, технические документы, рабочие материалы и т.п., в которых отражена защищаемая информация, относящаяся к ИСПДн «Кадры» и их криптографической защите, включая документацию на СКЗИ и на технические и программные компоненты СФ;

5. носители защищаемой информации, используемые в информационной системе в процессе криптографической защиты персональных данных, носители ключевой, парольной и аутентифицирующей информации СКЗИ и порядок доступа к ним;

6. используемые информационной системой каналы (линии) связи, включая кабельные системы;

7. помещения, в которых находятся ресурсы информационной системы, имеющие отношение к криптографической защите персональных данных.

В соответствии с нормативными документами ФСБ России все физические лица, имеющие доступ к техническим и программным средствам ИС, разделяются на следующие категории:

- лица, имеющие право постоянного доступа в КЗ ИС (сотрудники, имеющие доступ к ИС, зарегистрированные пользователи ИС других организаций, обслуживающий персонал);

- лица, имеющие право разового доступа в КЗ ИС (посетители и обслуживающий персонал, лица, осуществляющие ремонт, обслуживание и сопровождение программных, технических и программно-технических средств ИС, в том числе СЗИ);

- привилегированные внутренние пользователи ИС;

- внешние источники атак.

Все потенциальные нарушители подразделяются на:

– внешних нарушителей, не имеющих доступа к ИС и осуществляющих атаки из-за пределов КЗ ИС;

– внутренних нарушителей, осуществляющих атаки, находясь в пределах КЗ ИС, включая пользователей ИС, и реализующих угрозы непосредственно в ИС.

Предполагается, что внешние источники атак, имеющие или не имеющие права доступа в КЗ ИС, могут рассматриваться в качестве потенциальных источников атак.

Привилегированные внутренние пользователи – члены группы администраторов, являются особо доверенными лицами, которые осуществляют обслуживание технических и программных средств СКЗИ и СФ, включая их настройку, конфигурирование и распределение ключевой документации между непривилегированными внутренними пользователями. К их числу относятся ответственный за обеспечение безопасности информации в ИС и ответственный пользователь СКЗИ.

Предположения об отнесении категории физических лиц к потенциальным источникам атак представлены в таблице 20.

Таблица 20 – Потенциальные источники атак

Категория физических лиц	Предположение об отнесении категории физических лиц к потенциальным источникам атак	Обоснование предположения об отнесении категории физических лиц к потенциальным источникам атак
Лица, имеющие право постоянного доступа в КЗ ИС	Да	– обслуживающий персонал и лица, обеспечивающие функционирование ИС, имеют возможность находиться в помещениях, где расположена ИС, в отсутствие пользователей ИС; – работа внутренних пользователей ИС регламентирована;
Лица, имеющие право разового доступа в КЗ ИС	Да	– ремонт, обслуживание и сопровождение программных, технических и программно-технических средств ИС, в том числе СЗИ, выполняется доверенными лицами, с выполнением мер по обеспечению безопасности информации; – в помещениях, в которых происходит обработка информации, возможно нахождение посторонних лиц; – обслуживающий персонал и лица, обеспечивающие функционирование ИС, имеют возможность находиться в помещениях, где расположена ИС, в отсутствие пользователей ИС.
Привилегированные внутренние пользователи ИС	Нет	– ремонт, обслуживание и сопровождение программных, технических и программно-технических средств ИС, в том числе СЗИ, выполняется доверенными лицами, с выполнением мер по обеспечению безопасности информации;

Категория физических лиц	Предположение об отнесении категории физических лиц к потенциальным источникам атак	Обоснование предположения об отнесении категории физических лиц к потенциальным источникам атак
		— ответственный за обеспечение безопасности информации, ответственный пользователь СКЗИ назначаются из числа особо доверенных лиц.
Внешние субъекты (физические лица)	Да	— имеют возможность осуществлять создание способов реализации угроз, подготовку и реализацию угроз информационной безопасности только за пределами КЗ

На основании исходных данных об ИС, объектах защиты и источниках атак определены обобщенные возможности источников атак, которые описаны в таблице 21.

Таблица 21 – Обобщенные возможности источников атак

№	Обобщенные возможности источников атак	Предположение о возможности источников атак
1.	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак только за пределами КЗ	Да
2.	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах КЗ, но без физического доступа к аппаратным средствам, на которых реализованы СКЗИ и среда их функционирования	Да
3.	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах КЗ с физическим доступом к аппаратным средствам, на которых реализованы СКЗИ и среда их функционирования	Да
4.	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области анализа сигналов линейной передачи и сигналов побочного электромагнитного излучения и наводок СКЗИ)	Нет
5.	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных возможностей прикладного программного обеспечения)	Нет

№	Обобщенные возможности источников атак	Предположение о возможности источников атак
6.	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных возможностей аппаратного и программного компонентов среды функционирования СКЗИ)	Нет

Реализация угроз безопасности персональных данных, обрабатываемых в информационных системах персональных данных, определяется возможностями источников атак. Таким образом, актуальность использования возможностей источников атак определяет наличие соответствующих актуальных угроз.

Анализ уточненных возможностей нарушителей и направления атак, исходя из обобщенных возможностей источников атак, приведен в таблице 22.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .

E-mail: dporzn@yandex.ru

Таблица № 22. Уточненные возможности нарушителей и направления атак

№ п/п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
1.1	Проведение атаки при нахождении в пределах КЗ	Актуально	
1.2	Проведение атак на этапе эксплуатации СКЗИ на следующие объекты: документацию на СКЗИ и компоненты СФ; помещения, в которых находится совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем, на которых реализованы СКЗИ и СФ	Неактуально	Отсутствуют объективные предпосылки для осуществления угрозы: – ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; – документация на СКЗИ хранится у ответственного пользователя СКЗИ в металлическом сейфе (шкафу); – помещения, в которых располагаются документация на СКЗИ, СКЗИ и СФ оснащены входными дверьми с замками; – обеспечивается постоянное закрытие дверей помещений, в которых располагаются документация на СКЗИ, СКЗИ и компоненты СФ, на замок и их открытие только для санкционированного прохода; – утвержден перечень лиц, имеющих право доступа в помещения.
1.3	Получение в рамках предоставленных полномочий, а также в результате наблюдений следующей информации:	Неактуально	Объективные предпосылки для реализации угрозы отсутствуют: – сведения о физических мерах защиты объектов, в которых размещены СКЗИ, доступны ответственным за обеспечение безопасности информации, администраторам ИСПДн;

№ п\п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
	сведений о физических мерах защиты объектов, в которых размещены ресурсы информационной системы; сведений о мерах по обеспечению КЗ объектов, в которых размещены ресурсы информационной системы; сведений о мерах по разграничению доступа в помещения, в которых находятся СВТ, на которых реализованы СКЗИ и СФ		– ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; – ответственный за обеспечение безопасности информации, администраторы ИСПДн назначаются из числа особо доверенных лиц;
1.4	Использование штатных средств ИСПДн, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий	Неактуально	Объективные предпосылки для реализации угрозы отсутствуют: – ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; – ответственный за обеспечение безопасности информации, администраторы ИСПДн назначаются из числа особо доверенных лиц; – работа пользователей ИСПДн и пользователей СКЗИ регламентирована; – помещения, в которых располагаются СВТ, на которых располагаются СКЗИ и СФ, оснащены входными дверьми с замками,

№ п\п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
			обеспечивается постоянное закрытия дверей помещений на замок и их открытия только для санкционированного прохода; – сотрудники проинформированы об ответственности за несоблюдение правил обеспечения безопасности информации.
2.1	Физический доступ к СВТ, на которых реализованы СКЗИ и СФ	Неактуально	Объективные предпосылки для реализации угрозы отсутствуют: – доступ в контролируемую зону и помещения, где располагается СВТ, на которых реализованы СКЗИ и СФ, обеспечивается в соответствии с контрольно-пропускным режимом; – помещения, в которых располагаются СВТ, на которых располагаются СКЗИ и СФ, оснащены входными дверьми с замками, обеспечивается постоянное закрытия дверей помещений на замок и их открытия только для санкционированного прохода
2.2	Возможность воздействовать на аппаратные компоненты СКЗИ и СФ, ограниченная мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий	Неактуально	– в помещениях, в которых находятся СКЗИ и СФ невозможно нахождение посторонних лиц; – ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; – помещения, в которых располагаются документация на СКЗИ, СКЗИ и СФ оснащены входными дверьми с замками; – обслуживающий персонал и лица, обеспечивающие функционирование ИСПДн, не имеют возможность находиться в помещениях, где расположены СКЗИ и СФ

№ п\п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
3.1	Создание способов, подготовка и проведение атак с привлечением специалистов в области анализа сигналов, сопровождающих функционирование СКЗИ и СФ, и в области использования для реализации атак недокументированных (недекларированных) возможностей прикладного ПО	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности. – высокая стоимость и сложность подготовки реализации возможности
3.2	Проведение лабораторных исследований СКЗИ, используемых вне КЗ, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности. – высокая стоимость и сложность подготовки реализации возможности

№ п\п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
	несанкционированных действий		
3.3	Проведение работ по созданию способов и средств атак в научно- исследовательских центрах, специализирующихся в области разработки и анализа СКЗИ и СФ, в том числе с использованием исходных текстов входящего в СФ прикладного ПО, непосредственно использующего вызовы программных функций СКЗИ	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности. – высокая стоимость и сложность подготовки реализации возможности
4.1	Создание способов, подготовка и проведение атак с привлечением специалистов в области использования для реализации атак недокументированных	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности. – высокая стоимость и сложность подготовки реализации возможности

№ п\п	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1	2	3	4
	(недекларированных) возможностей системного ПО		
4.2	Возможность располагать сведениями, содержащимися в конструкторской документации на аппаратные и программные компоненты СФ	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности.
4.3	Возможность воздействовать на любые компоненты СКЗИ и СФ	Неактуально	– не осуществляется обработка сведений, составляющих государственную тайну, а также иных сведений, которые могут представлять интерес для реализации возможности.

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**
390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .
E-mail: dporn@yandex.ru

В соответствии с изложенным выше предположениями о наличии возможностей у нарушителей на проведение атак и в соответствии с Приказом ФСБ России от 10 июля 2014 г. № 378 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности» в ИСПДн «Кадры» должны применяться СКЗИ класса не ниже КС2.

11. Выводы

В результате разработки модели угроз и нарушителей безопасности информации, обрабатываемой в ИСПДн «Кадры» был определён перечень актуальных угроз.

Каждая из угроз безопасности, включённых в перечень, должна быть нейтрализована с помощью проведения мероприятий по созданию подсистемы защиты информации, путем выбора мер защиты, нейтрализующие данные угрозы и подбора соответствующих сертифицированных средств защиты информации.